

Firestore Security Rules — Deployment Checklist

Visitor Management System — generated 2026-08-19

1. Deploy the rules

Requires the Firebase CLI and login credentials. `firebase.json` already points to `firestore.rules`.

```
npm install -g firebase-tools
firebase login
firebase use --add          # no .firebaserc exists yet — link your project
firebase deploy --only firestore:rules
```

This only pushes rules; it does not touch the database or hosting.

2. Verify (before or after deploy)

1. Firebase console → Firestore → **Rules playground** → test key scenarios:
 - Host creates a `Pre-Registered` visit tied to their own UID → allowed.
 - Host reads a visit where `registeredBy != auth.uid` → denied.
 - Host updates only `registrationEmailSent` → allowed; changing `status` → denied.
 - Reception badge check-in `Pre-Registered` → `Active` → allowed.
 - Extend visit, stay-monitor reminders, check-out `Active` → `Checked Out` → allowed.
 - Anonymous read of `visitors` / `frequentVisitors` → denied.
 - Super Admin delete of a visit record → allowed.
2. Then run each role for real: Host pre-registers → Reception checks in by badge → extend → stay-monitor reminders → check-out.

3. App-side consequences (the only real work left)

The rules now block the **anonymous kiosk** at `/`. With no app change, an unauthenticated user hitting `/` gets permission-denied on `visitors` / `frequentVisitors`.

1. To keep a self-service kiosk working, make the kiosk authenticated — e.g. require Reception/Security login before the check-in screen. Everything already works for logged-in staff: `CheckInForm`, `AdminVisitors`, `StayMonitor`, `ExtendVisitModal`, `HostRegisterVisitor`, `HostDashboard` write exactly the fields the rules allow.
2. “Save as Frequent Visitor” on the kiosk (`DigitalBadge`) now fails for anonymous users — either leave it, or gate/remove it.

4. Optional

- Add `.firebaserc` / run `firebase init` to set a default project.
- Update any `Documentation/*.md` that still describes public kiosk access.

Status: The rules file and matching `firestore.rules.pdf` are done and correct as-is. The open question is whether to make the kiosk require staff login, or accept staff-only check-in.